

TCS3351 Cryptography and Data Security

Tutorial 1

Introduction: Security Goals, Services, Mechanisms, Cryptosystems

1. What do you mean by CIA Triad? Briefly explain each security goal with an example.

Answer:

CIA Triad is a major goal of data security that comprises confidentiality, integrity, and availability.

- a) **Confidentiality:** It ensures the secrecy of the transmitted data from passive attacks such as interruption and traffic analysis.
- b) **Integrity:** Assurance of the exact same data sent and received without having been altered, modified, or replayed.
- c) **Availability:** It describes the accessibility of the resource or data to always authorized users all the time.

2. What is the difference between passive and active security attacks? State the general approach that can be used for handling each type of these attacks.

Answer:

- a) Passive attack: Listen only. Does not send any traffic if possible.
The attacker does not perform modification to the content of the data sent. For instance, snooping and traffic analysis.
 - To prevent snooping – the sent data is encrypted.
Instead of ftp use sftp
Instead of telnet use ssh
Instead of http use https
 - To prevent traffic analysis – the sent data is randomized, padding (everything looks the same size).

Is the first thing attacker do before any active attack.

- b) Active attack: The attacker performs changes to the content of the original data sent. For example, interruption, alteration (modification), and fabrication.
 - To prevent interruption – installation of antivirus/malware to block potential DoS attack.
 - To prevent alteration (modification) – the data is signed digitally.
 - To prevent fabrication – the user's identities are identified before sending data (identification).

Some DOS attacks do modify the packet. It's take an IP packet, and mesh up all the relevant field in IP and transport header, then the packet is sent to the destination. Small OS with limited programming budget, low development budget such as IOT may hang, crashed etc.

Some DOS attack do not modify the packet instead it just sends many irrelevant packets to the destination.

3. Give an example of the DOS type of attacks that will threaten availability and explain briefly.

Answer:

Denial of Service (DoS) or interruption. The type of attack that causes data or information unavailable and inaccessible by authorized entities.

SPAMMING :- EMAIL :- Send 10000 email to the receiver, the receiver wasting time reading unrelated email.

Network : Exhausted the resource (Bandwidth and CPU).

CPU exhaustion : Send an SQL request that need to dump/search a large table.

Process a large process from a large database.

Attacker may send some packets that may hang/crashes the server.

4. Briefly explain the meaning of the following terms related to security services:

- (i) authentication
- (ii) non-repudiation

Answer:

- i. Authentication: The assurance of the communication entities is the one that claims to be, and the origin of the data sent is verifiable.
- ii. Non-repudiation: The prevention of communicating entities to deny the data sent and received.

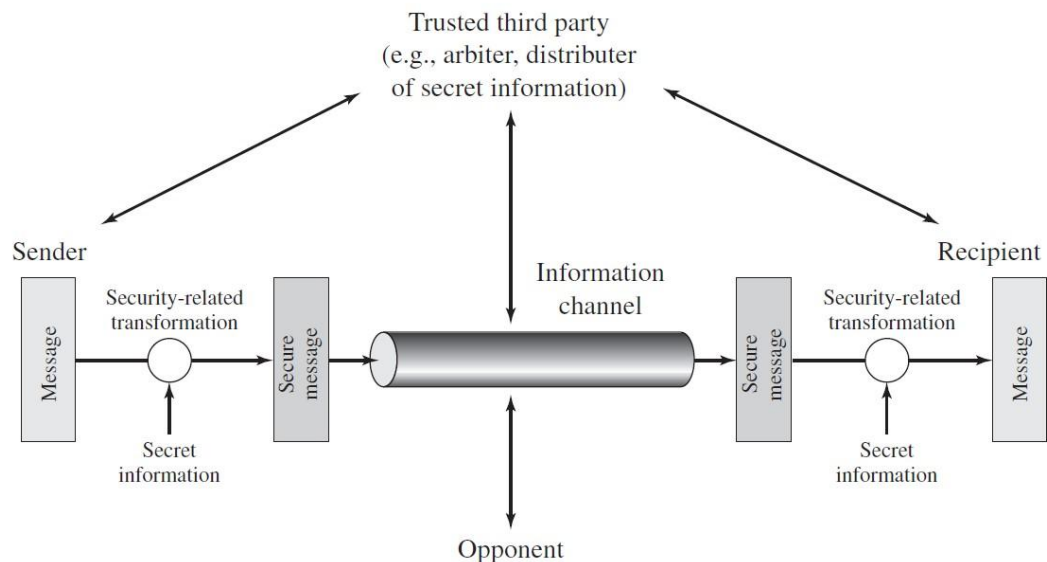
For non-repudiation.

Sender verification : easy

Receiver confirmation : hard super hard! Almost impossible. E.g

<https://www.facebook.com/reel/3670665893228854>

5. Briefly discuss the basic model for network security and explain how person A can transmit the information in a secure manner to person B using this model.



Answer: TTP that distribute the keys. (encryption keys and algo).

When person A (sender) intends to send a message secretly to person B (receiver), he will first request TTP to obtain secret information, which allows him to transform the data into a secure message via some transformation techniques. The secure message is transmitted through the information channel, where the potential opponent may intercept and obtain it for an attack. Person B, who receives the secure message, will request his secret information from TTP (whenever necessary) to transform the secure message back into a readable original message.

6. Briefly describe the model for network access security with typical measures to be taken for security. Access Control List (who can access what).

Answer:

The network access model provides protection for a system from unwanted access, particularly information access threat and service threat. To enhance the security of such a system, two possible measurements could be taken:

- a) Utilization of gatekeeper function: To establish a password for the user's login to deny or reject unauthorized access or to design screening logic to detect and block potential viruses and malware.
- b) Implementation of internal security controls: To monitor and analyze information and activity and attempts to detect the presence of intruders or viruses.

In any online system, the password is not stored. Only the hashes of the password are stored in the system. Thus, nobody except the user has the password to access the system. Therefore, the user cannot blame anyone. When users enter their password, it will be hashed along with other details such as username, salt etc. If the hash matches with the one stored in the system, then the user is authenticated.

7. Identify the type of security attack in the following example and briefly explain the reason for your answer. When purchasing an item from the seller, person A gave an instruction to the bank to deduct RM 500. :Request

Later person A found that instead of RM500, RM5000 was deducted from the account.
How can you avoid this type of attack? :Outcome.

Confidential, **Integrity**, replay, non-repudiation?

Answer:

Modification / alteration. Integrity property is violated. The transaction should be hashed + signed. ~~encrypted so~~ that the transaction amount cannot be modified by an unauthorized party. In addition, the implementation of a digital signature can be done for validation by the receiver bank.

Integrity : Hash the msg content with share password. (no confidentiality). Can prevent msg modification.

8. Briefly explain the differences between symmetric and asymmetric cryptography models.

Answer:

- a) Symmetric cryptography: Uses only a single private key in the encryption and decryption process. Both sender and receiver share this same private key.
- b) Asymmetric cryptography: Uses two different keys – a public key and a private key. The sender uses the public key to encrypt plaintext, while the receiver uses the private key to decrypt the ciphertext.

Only asymmetric cryptography can do non-repudiation as only the sender has the private key to sign any document.

However symmetric cryptography are faster,

can process large messages

and cryptographically more secure (as part of the keys are not disclosed).

9. Answer the following questions with respect to symmetric cryptography.

In a cricket team, there are '11' players.

- (i) How many keys are needed if all the players need to send secret messages to each other? NO coach is involved.
- (ii) How many keys are needed if everyone trusts the team's coach? If a player needs to send a message to another player, he/she first sends it to the coach, and the coach then sends the message to the other student.

Answer:

The number of keys for (i) is similar to a fully mesh topology. $N(n-1)/2$. Which is 55 keys

What is the conclusion from your calculation if you do symmetric encryption?

Key explosion as the number of players increased.

Key distribution problem, so many keys how r u going to distribute them securely , remotely via online.

ii) $A1 \leftrightarrow \text{Coach}$, $A2 \leftrightarrow \text{Coach}$, ... $A11 \leftrightarrow \text{Coach}$.

11 keys. Trusted 3rd party!

10. Repeat Question 9, assuming the usage of asymmetric cryptography.

Answer:

i. 22 keys: 11 public keys and 11 private keys.

ii. 2 keys. 1 public key and 1 private key.***
(Additional details to be announced later).

References:

- Behrouz A Forouzan, Debdeep Mukhopadhyay, “Cryptography and Network Security”, Third Edition, Mc-Graw Hill Education, 2015.
- William Stallings and Lawrie Brown, “Computer Security: Principles and Practice”, Fourth Edition, Prentice Hall, 2018.
- William Stallings, “Cryptography and Network Security – Principles and Practice”, Seventh Edition, Prentice Hall, 2017.
- Atul Kahate, "Cryptography and Network Security", Fourth Edition, McGraw-Hill Education, 2019.